

GRCEEK

Business Requirements Document

BRD

Brought to you by



Document Control

Document Title: Business Requirements Document

Project Name: GRCEEK

Date: 3 June 2025

Author: Ahmed Alaa

Document Version: V1.0

Document Control:

Version No	Date	Modification Description	Prepared By	Verified by	Approved By
1.0	3 June 2025	Create the document	Ahmed Alaa		

Table of Contents

GRCEEK.....	1
Executive Summary.....	4
Project Overview.....	5
Project Description:.....	5
Business Objectives:.....	5
Mission, Vision, Goals, and Business Needs.....	6
Mission.....	6
Vision.....	6
Goals.....	6
Scope of the Document.....	7
Full system workflow.....	8
Functional Requirements.....	9
1. User Management.....	9
2. Incident Reporting.....	15
3. Framework Management.....	19
4. Risk Management.....	22
5. Control Management.....	25
6. Policy Management.....	28
7. Workflow Configuration.....	31
8. Custom Reports.....	33
9. Framework Score Calculation.....	35
10. Auditor Functionalities.....	36
11. System Configuration.....	38
12. Roles and Permissions.....	40
12. Notification.....	42
List of Actors.....	45
Non-Functional Requirements.....	48
Assumptions.....	50
Constraints.....	51
Glossary and Acronyms.....	52
Conclusion.....	54

Executive Summary

This **Business Requirements Document (BRD)** outlines the comprehensive solution requirements for the development of the Governance, Risk, and Compliance (**GRC**) system, a web-based platform designed to enhance organizational governance, risk management, policy enforcement, and compliance operations. The document is structured to provide a clear understanding of the project's mission, vision, goals, and objectives, along with detailed functional and non-functional requirements for each module.

The GRC System project aims to modernize and streamline governance, risk, and compliance processes, improving user experience and operational efficiency for organizations. This solution focuses on secure user management with Role-Based Access Control (RBAC), dynamic framework management (ISO 27001, NIST, GDPR, COSO), policy enforcement. Key modules include User Management, Incident Reporting, Risk Management, Control Management, Policy Management, Framework Management, Workflow Configuration, and Reporting/Dashboards. The platform features Internal/External Auditor roles for commenting and approval, and framework score calculations (automatic/manual). By automating manual processes (status workflows, auditor reviews) and providing robust reporting tools, the GRC system empowers organizations to achieve seamless, secure, and compliant operations while optimizing governance workflows.

Project Overview

Project Description:

The GRC system is a web-based platform designed to provide seamless and secure governance, risk management, policy enforcement, and compliance for organizations. The platform caters to global organizational users, including Compliance Officers, Auditors, and Admins, with features like secure user management, framework management (ISO 27001, NIST, GDPR), policy enforcement, auditor comment and approval workflows, and compliance reporting.

Business Objectives:

- Provide a secure and user-friendly platform for governance, risk management, policy enforcement, and compliance processes.
- Ensure compliance with global standards (ISO 27001, NIST, GDPR, COSO) and organizational policies.
- Enhance user experience with features like Role-Based Access Control (RBAC), auditor comment workflows, and automated framework scoring.
- Streamline compliance management for back-office users with tools for framework, policy, control, and risk management.
- Implement a robust reporting system for compliance status, framework scores, and audit outcomes.

Mission, Vision, Goals, and Business Needs

Mission

To transform organizational governance, risk management, and compliance by providing a seamless, secure, and user-friendly web-based platform that empowers users to manage frameworks, enforce policies, and ensure compliance while enabling efficient back-office operations for compliance teams.

Vision

To become the leading GRC platform globally, delivering innovative solutions that enhance compliance, risk and policy management, and drive organizational trust through advanced technology and exceptional user experience.

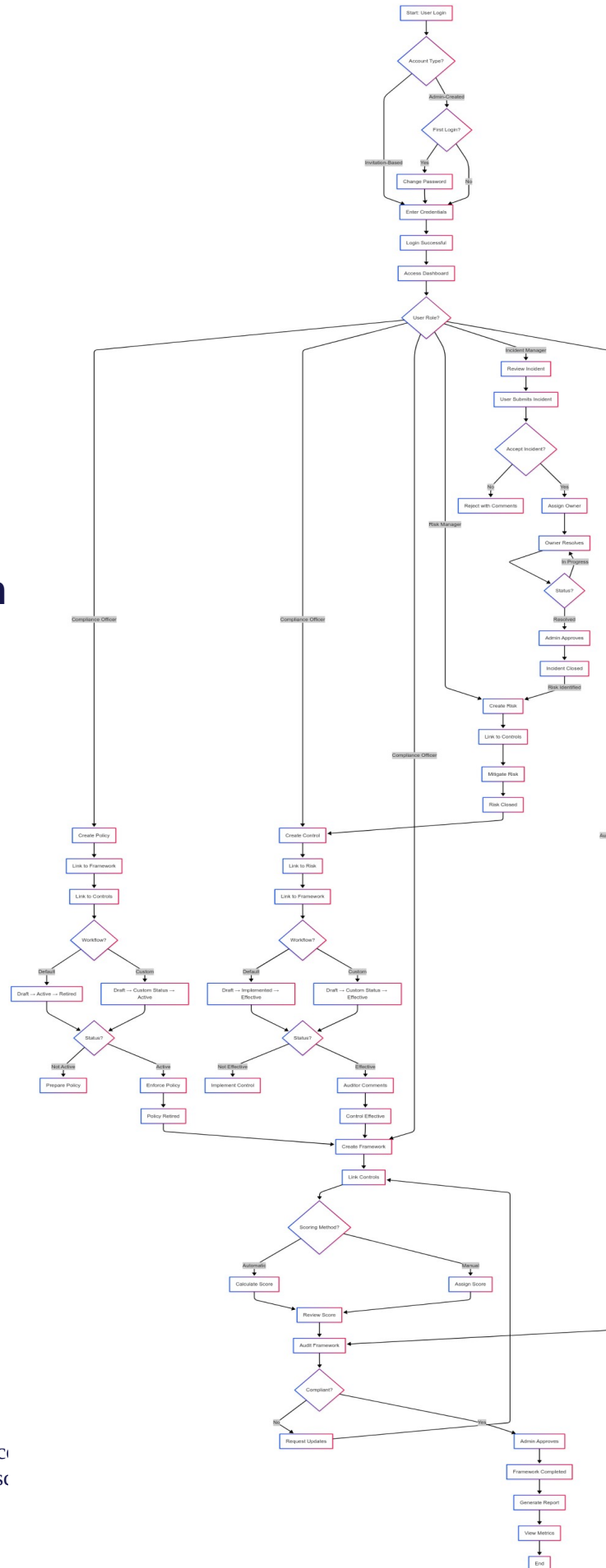
Goals

- **User-Centric Experience:** Deliver an intuitive and seamless experience for Compliance Officers, Auditors, and Admins through responsive design and streamlined workflows.
- **Operational Efficiency:** Optimize framework, policy, control, and risk management processes with workflows and robust reporting tools.
- **Security and Compliance:** Ensure data security, user privacy, and adherence to global standards (ISO 27001, NIST, GDPR, COSO).
- **Organizational Trust:** Foster trust through auditor comment workflows, accurate framework scoring, and transparent compliance reporting.

Scope of the Document

- **User registration, authentication, and profile management** with Role-Based Access Control (RBAC).
- **Secure compliance** processes through **framework management** (ISO 27001, NIST, GDPR, COSO) and policy enforcement.
- **Incident Management**: tracking and resolving compliance incidents with evidence uploads.
- **Risk Management**: assessing and mitigating risks with likelihood/impact scoring.
- **Control Management**: implementing and testing controls with effectiveness ratings.
- **Policy Management**: creating, enforcing, and reviewing policies linked to frameworks and controls.
- **Framework Management**: defining and scoring compliance frameworks with auditor workflows.
- **Workflow Configuration**: designing automated status workflows with admin approvals.
- **System Configuration**: Management of categories (like: Operational for risks, Regulatory for frameworks) for risks, compliance, frameworks, controls, incidents, and policies, enabling customizable taxonomies.
- **Roles and Permissions**: Definition and management of roles (like: Compliance Officer, Auditor) with granular permissions (Create, Read, Update, Delete) per module and configuration of role-based notifications for all actions within specified modules.
- **Notification**: Automated alerts via two methods: template-based notifications for specific events (like: incident submitted, risk closed) and role-based notifications for all actions in configured modules (like: all Risk Management actions), delivered via email or in-website with user preference settings.
- **Reporting and Analytics**: Generating real-time reports and dashboards for compliance status, framework scores, risk metrics, and audit outcomes, with category-based filtering and export options (CSV).
-

Full system workflow



Functional Requirements

1. User Management

Purpose

Manage user accounts and roles with Role-Based Access Control (RBAC), enabling Admins to create user accounts or invite users by sending role-specific invitation links via email or copied links, allowing invited users to complete their data and log in, ensuring secure access, mandatory password changes for first-time logins with Admin-created accounts, and preventing deletion of users who interacted with the system (like: created policies).

Features

- Allow Admins to send invitation links to users by selecting their role, delivered via email or as a copied link for manual sharing.
- Enable invited users to complete their account data (name, email, password, department) using the invitation link and log in upon completion.
- Enable Admins to create user accounts directly with predefined roles and permissions.
- Require users to change their password upon first login for Admin-created accounts.
- Create, read, update, delete, and deactivate user accounts.
- Assign roles (Admin, Compliance Officer, Internal Auditor, External Auditor, Risk Manager, Control Owner).
- Enforce strong passwords (8+ characters, uppercase, lowercase, numbers, special characters).
- Track user interactions for auditability and retain names of deactivated users in records (like: creator fields).

User Completion Form (Via Invitation Link) or admin creation

Field	Description	Validation
User ID	Unique alphanumeric ID (USER123)	Auto-generated, non-editable

Name	Full name	Required, text, min 5, max 100 characters, letters/spaces
Email	User email	Required, valid email format, unique
Password	Initial password (Admin-created) or user-entered (Sign-Up)	Required, 8+ characters, uppercase, lowercase, numbers, special characters
Confirm Password	Password confirmation	Required, must match Password
Role	Predefined/custom role	Required, dropdown (Admin, Auditor), editable by Admin only
Department	User department	Optional, text, max 50 characters
Status	Account status (Pending/Active/Inactive)	Auto-set (Pending for Sign-Up, Active for Admin-created, inactive if admin deactivate it), dropdown

Admin Invitation Form (Initiates Invitation)

Field	Description	Validation
Email	User's email for invitation	Required, valid email format, unique
Role	Predefined role	Required, dropdown (Admin,

		Auditor)
Invitation Method (3 days expiry & can be changed by admin from the settings)	Delivery method (Email or Copy Link)	Required, dropdown

CRUD Operations

- **Create:**
 - **Invitation-Based:**
 - Admin selects Role, Permissions, Email, and Invitation Method; system generates unique invitation link.
 - For Email, system sends link to user's email; for Copy Link, Admin copies link to share manually for invitations list or when he choose copy link when he submit the form pop-up will appear and can copy link from it.
 - User accesses link, completes Name, Password, and Department; system sets Status to Pending.
 - **Admin-Created:**
 - Admin enters Name, Email, Role, Permissions, and Department; system generates User ID and Temporary Password.
 - Status set to Active; user must change password on first login.
- **Read:** View user profiles, roles, permissions, and interaction history (like: created controls).
- **Update:**
 - Admins modify details (Email, Role).
 - Users change any data except id and role and can change password via profile settings or on first login (Admin-created accounts).
- **Delete:** Deactivate only (Status: Inactive); deletion blocked for users with interactions (created a policy); names retained in records ("Creator: Ahmed Alaa").

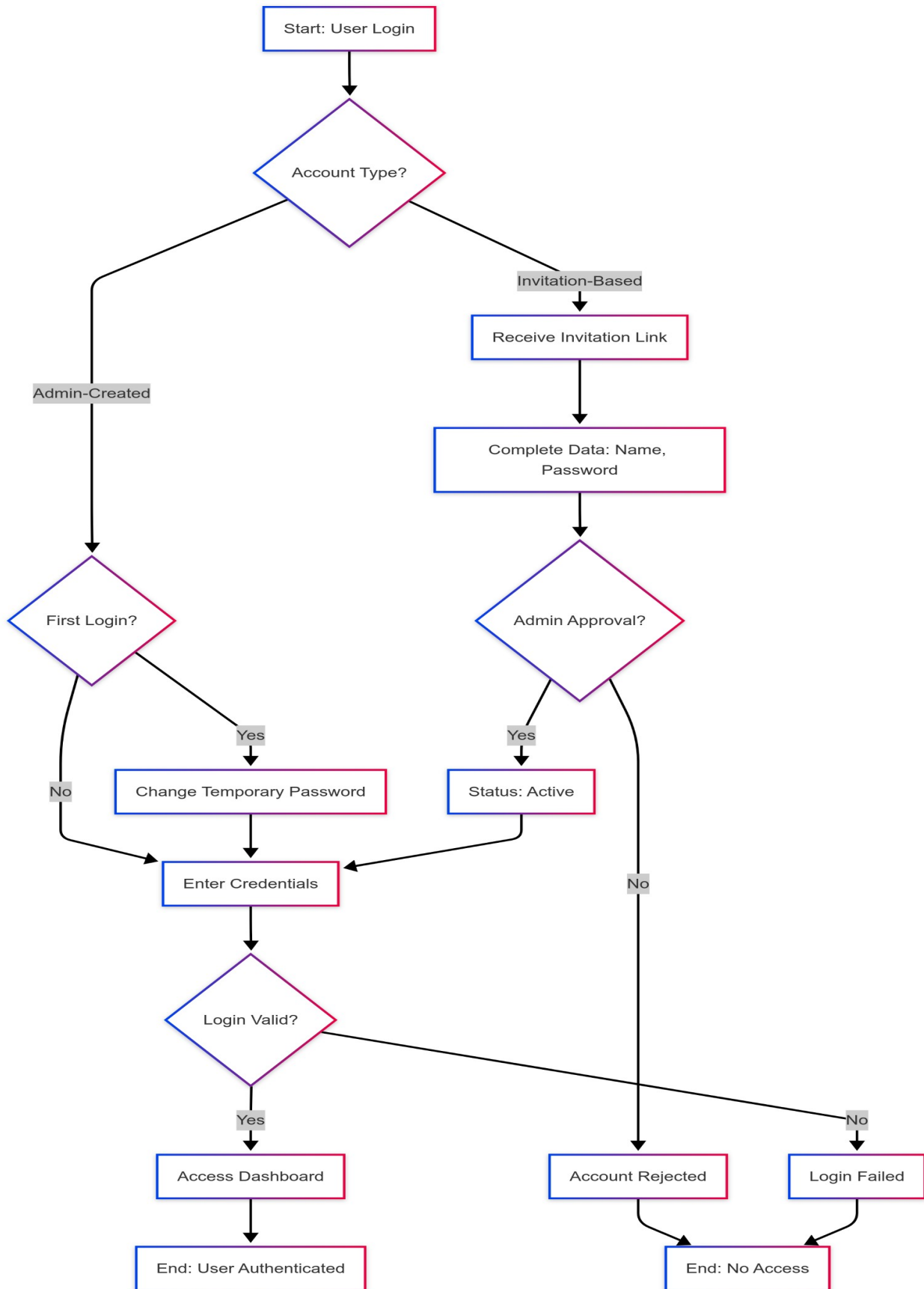
Status Cycle

- **Pending:** Invitation sent; user completed data.
- **Active:** User can access system based on role/permissions.

- **Inactive:** User cannot log in; applied for deactivated accounts.

Workflow

- **Invitation-Based Sign-Up:**
 - Admin selects Role, Email, and Invitation Method (Email/Copy Link); system generates link with 3-day default expiry.
 - User receives link (via email or manual sharing), accesses form, and completes Name, Password, Department; Status set to Pending.
- **Admin-Created Account:**
 - Admin creates account with Name, Email, Role, Department, and Temporary Password; Status set to Active.
 - User logs in with Temporary Password; system prompts for new Password (strong password criteria).
 - User updates Password; login proceeds; actions logged.
- **Deactivation:**
 - Admin attempts to deactivate user; system checks interactions.
 - If interactions exist, deletion blocked; Status set to Inactive; name persists in records.
- **Password Change:**
 - Users change Password via profile settings (verify current Password).
 - First login for Admin-created accounts requires Password change.



2. Incident Reporting

Purpose

Track and resolve compliance incidents with evidence and status tracking, allowing Incident Managers to accept or reject submitted incidents and assign Owners to incidents for resolution.

Features

- Create, read, update, and delete incident reports.
- Allow Incident Managers to review, accept, or reject incidents, with rejection comments.
- Enable Incident Managers to assign Owners to incidents for resolution.
- Upload evidence files (PDFs, images).
- Track status through a defined cycle with admin/incident manager approvals.

Create Form Fields

Field	Description	Validation
Incident ID	Unique ID (INC123)	Auto-generated, non-editable
Title	Brief description	Required, text, min 5, max 100 characters
Description	Detailed explanation	Required, text, max 1000 characters
Category	Type (like: Security, Compliance)	Required, dropdown
Date Identified	Incident date	Required, MM/DD/YYYY, not future
Submitter	Reporter's name	Auto-filled, non-editable

Evidence	File uploads (PDF, JPG, PNG,MP4)	Required, max 10MB, PDF/JPG/PNG,MP4
Status	Current status (Submitted)	Auto-set to Submitted, non-editable on creation

CRUD Operations

- **Create:** Authorized users submit incidents; system sets Status to Submitted.
- **Read:** View incident details, history, evidence, status, and rejection comments (if any).
- **Update:**
 - Incident Managers accept (assign Owner, Status: Open) or reject (add comments, Status: Rejected).
 - Owners update details/status (to In Progress/Resolved).
 - Admins/Incident Managers add resolution notes or reassign Owners.
- **Delete:** Admins delete erroneous/rejected incidents; Submitter name retained in audit logs.

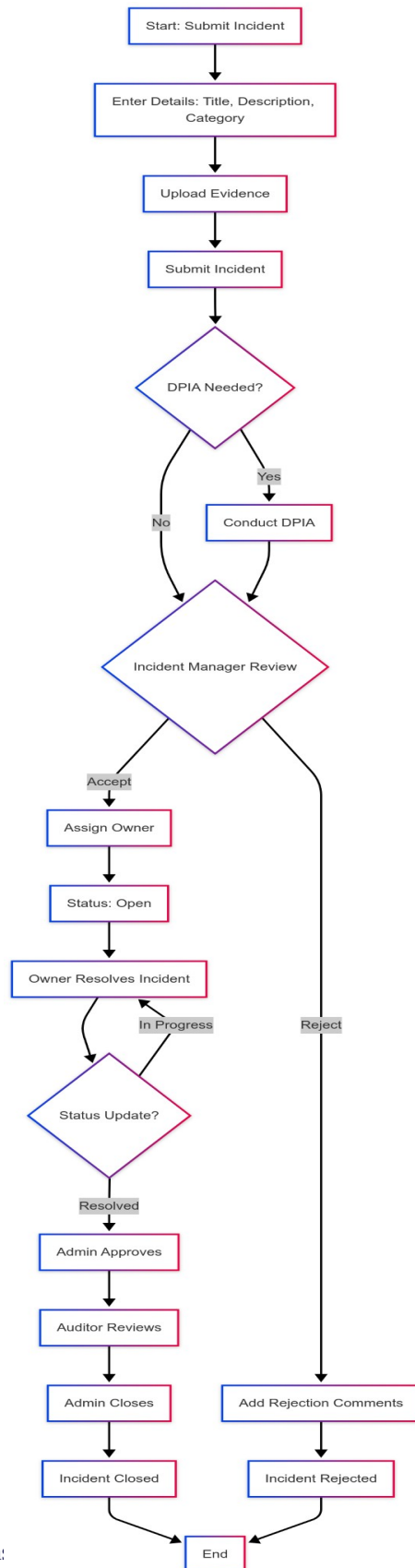
Status Cycle

- **Submitted:** Incident reported, awaiting Incident Manager review.
- **Rejected:** Incident rejected by Incident Manager with comments.
- **Open:** Incident accepted; Owner assigned for resolution.
- **In Progress:** Under investigation/resolution by Owner.
- **Resolved:** Corrective actions completed.
- **Closed:** Verified and archived post-audit.

Workflow

- User submits incident (Status: Submitted); system notifies Incident Manager.
- Incident Manager reviews:

-
- **Accept:** Sets Status to Open, assigns Owner (user via dropdown/search), notifies Owner.
 - **Reject:** Sets Status to Rejected, adds Rejection Comments, notifies Submitter.
 - Owner updates Status to In Progress/Resolved.
 - Admin finalizes as Closed.
 - All actions (submission, acceptance, rejection, assignment, status changes) logged in audit trail.



3. Framework Management

Purpose

Define and manage compliance frameworks (Like: ISO 27001) with scoring and auditor oversight.

Features

- Create, read, update, and delete frameworks.
- Link controls and calculate scores (automatic/manual).
- Link policies
- Allow auditor comments.
- Track framework status.

Create Form Fields

Field	Description	Validation
Framework ID	Unique ID (like: FRM123)	Auto-generated, non-editable
Name	Framework name (e.g., ISO 27001)	Required, text, min 5, max 100 characters, unique
Description	Overview	Required, text, min 5, max 1000 characters
Controls	Associated controls	Required, dropdown/search, min 1 control
Policies	Associated Policies	Required, dropdown/search, min 1 Policie

Scoring Method	Automatic/Manual	Required, dropdown
Framework Score	Total score (0–100)	From 0 to 100 only
Owner	Responsible user	Required, dropdown/search
Standard Reference	Details (like: ISO 27001:2022)	Optional, text, max 200 characters
Compliance Deadline	Compliance date	Required, MM/DD/YYYY, not past
Status	Current status (Active)	Required, dropdown, default Active

CRUD Operations

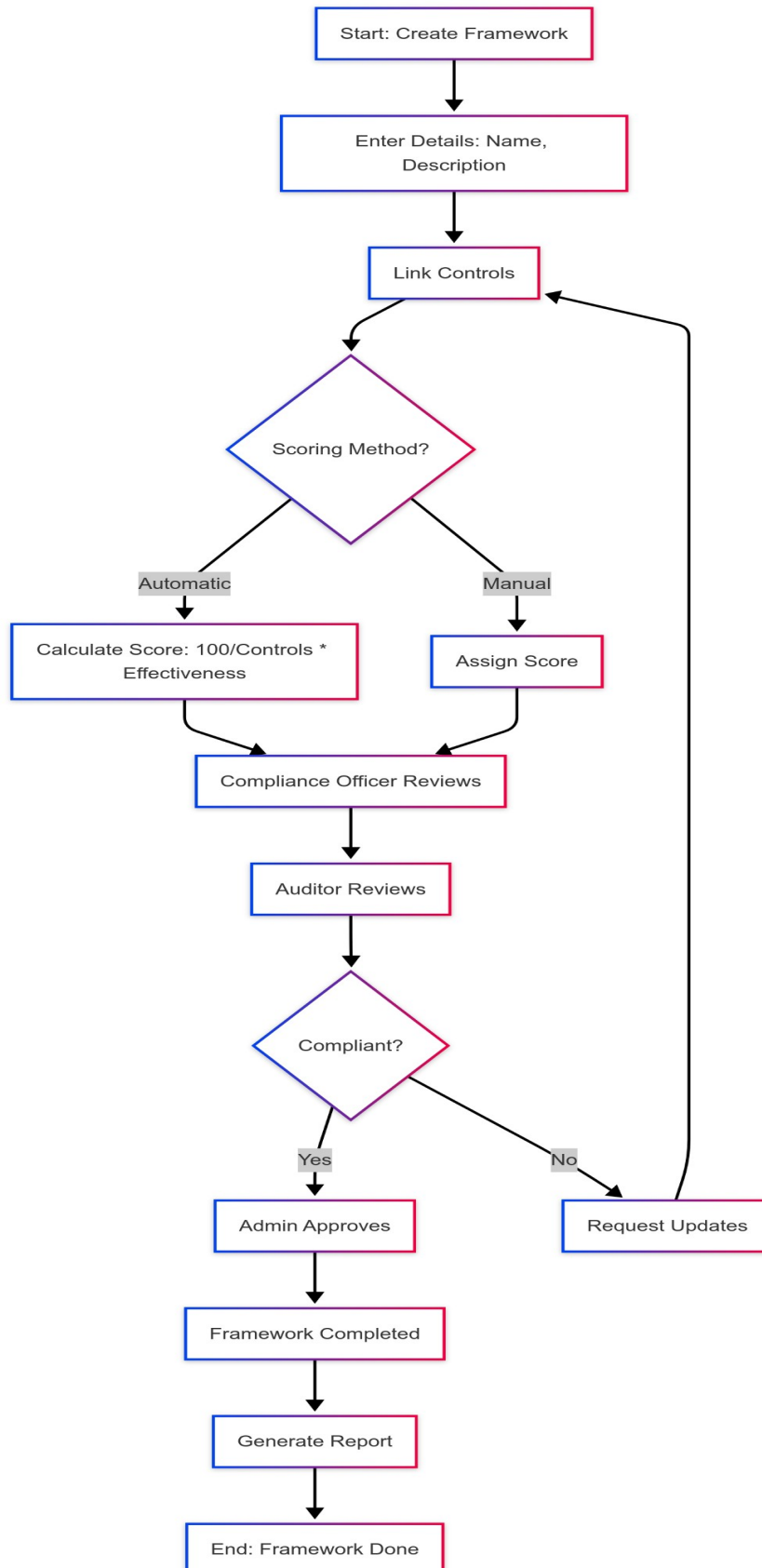
- **Create:** Compliance Officers create frameworks; link controls & policies, set scoring.
- **Read:** View framework details, scores, and comments.
- **Update:** Modify details/controls/scoring (via workflow).
- **Delete:** Admins remove obsolete frameworks; creator name retained.

Status Cycle

- **Active:** Framework in use, controls active.
- **Inactive:** Framework disabled (outdated) all controls will be disabled too.

Workflow

- Compliance Officer creates framework (Active); links controls & policies.
- System calculates score (Automatic: 25 points/control; Manual: custom).
- Auditors review, add comments on the controls.
- Admin finalizes status changes.



4. Risk Management

Purpose

Identify, assess, and mitigate risks (like: cybersecurity threats) with scoring and status tracking.

Features

- Create, read, update, and delete risks.
- Calculate risk scores based on likelihood and impact.
- Assign risks to owners for mitigation.
- Track status with admin-approved workflows.

Create Form Fields

Field	Description	Validation
Risk ID	Unique ID (like: RISK123)	Auto-generated, non-editable
Title	Risk description	Required, text, min 5, max 200 characters
Description	Detailed explanation	Required, text, min 5, max 1000 characters
Category	Type (like: Operational, Cybersecurity)	Required, dropdown
Likelihood	Probability (Rare to Almost Certain)	Required, dropdown, maps to 1–5
Impact	Consequence (Minor to Catastrophic)	Required, dropdown, maps to 1–4

Risk Score	Likelihood × Impact	Auto-calculated, non-editable (1–20)
Risk Owner	Responsible user	Required, dropdown/search
Controls	Associated controls	Required, dropdown/search, min 1 control
Mitigation Plan	Mitigation actions	Optional, text, max 1000 characters
Related Assets	Affected systems	Optional, text, max 500 characters

CRUD Operations

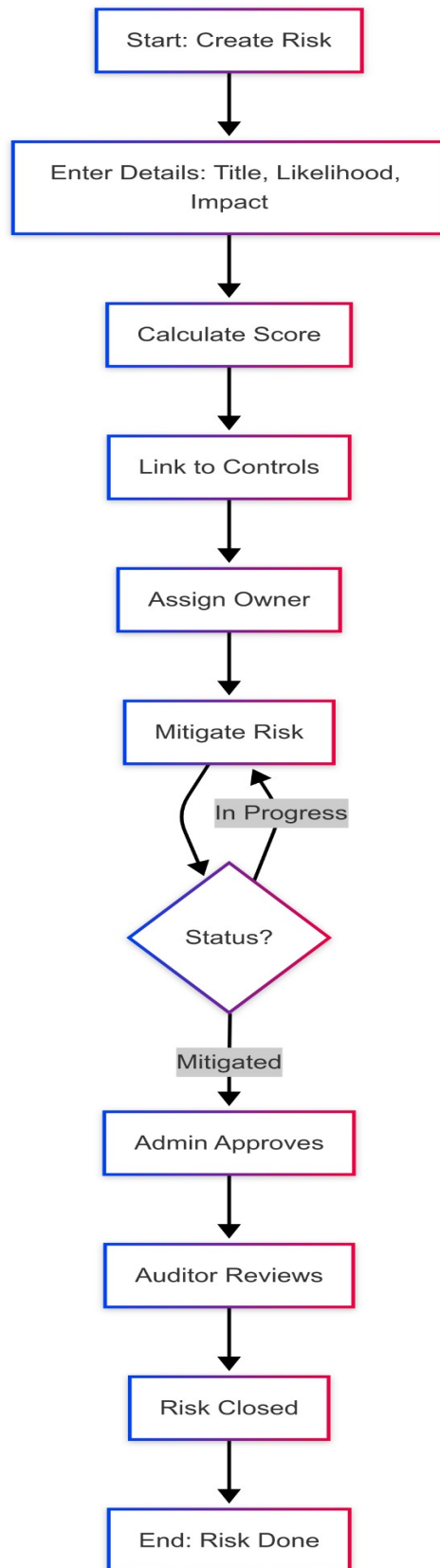
- **Create:** Risk Managers create risks; system calculates score.
- **Read:** View risk details, scores, and mitigation plans.
- **Update:** Update details/status (via workflow).
- **Delete:** Admins/Risk Managers remove resolved risks; creator name retained.

Status Cycle

- **Open:** Risk identified, awaits assessment.
- **In Progress:** Assessment/mitigation in progress.
- **Mitigated:** Mitigation completed.
- **Closed:** Verified as resolved.

Workflow

- Risk Manager creates risk (Open), assigns owner.
- Owner updates status to In Progress/Mitigated.
- Auditor reviews; Admin closes post-verification.



5. Control Management

Purpose

Implement and test controls (like: access control) to mitigate risks and ensure compliance to frameworks .

Features

- Create, read, update, and delete controls.
- Assign controls to owners for implementation.
- Rate control effectiveness (High, Medium, Low).
- Allow auditor comments.

Create Form Fields

Field	Description	Validation
Control ID	Unique ID (like: CTRL123)	Auto-generated, non-editable
Title	Control description	Required, text, min 5, max 100 characters
Description	Detailed explanation	Required, text, min 5, max 1000 characters
Category	Type (like: Preventive, Detective)	Required, dropdown
Assigned To	Responsible user	Required, dropdown/search
Related Risk	Linked risk	Optional, dropdown/search
Related Framework	Associated framework (like:	Required, dropdown/search

	ISO 27001)	
Status	Current status (Draft)	Auto-set, non-editable on creation
Effectiveness	Rating (High, Medium, Low)	Optional, dropdown

CRUD Operations

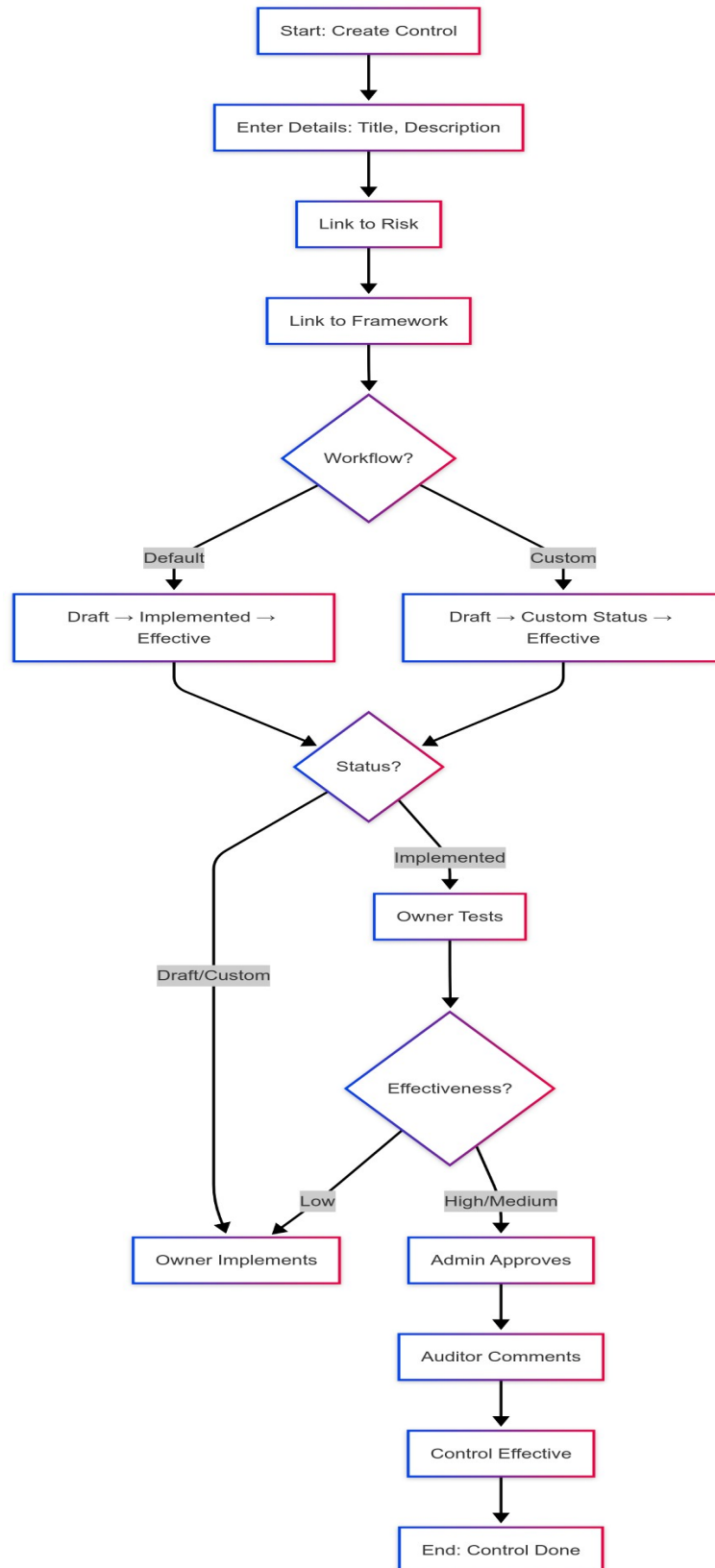
- **Create:** Compliance Officers create controls; link to frameworks.
- **Read:** View control details, effectiveness, and comments(From the auditors).
- **Update:** Update details/status/effectiveness (via workflow).
- **Delete:** Admins/Compliance Officers remove outdated controls; creator name retained.

Status Cycle

- **Draft:** Control defined, not implemented.
- **Implemented:** Control in place.
- **Effective:** Verified as effective.
- **Retired:** No longer needed, archived (Can't be linked to any new frameworks or risks).

Workflow

- Compliance Officer creates control (Draft), assigns owner to it.
- Owner updates status to Implemented/Effective.
- Admin updates status to Retired
- Auditors add comments..



6. Policy Management

Purpose

Create, enforce, and review policies to ensure compliance, linked to frameworks/controls.

Features

- Create, read, update, and delete policies.
- Link policies to frameworks and controls.
- Track policy lifecycle with status workflows.
- Allow auditor comments.

Create Form Fields

Field	Description	Validation
Policy ID	Unique ID (like: POL123)	Auto-generated, non-editable
Title	Policy title (like: Data Protection)	Required, text, min 5, max 100 characters
Description	Detailed explanation	Optional, text, max 2000 characters
Category	Type (like: Security, Privacy)	Required, dropdown
Owner	Responsible user	Required, dropdown/search
Related Framework	Linked framework (like: ISO 27001)	Required, dropdown/search
Related Controls	Linked controls	Optional, dropdown/search

Policy document	File uploads (PDF, JPG, PNG)	Required, max 10MB, PDF/JPG/PNG
Effective Date	Policy start date	Required, MM/DD/YYYY, not past
Status	Current status (Draft)	Auto-set, non-editable on creation

CRUD Operations

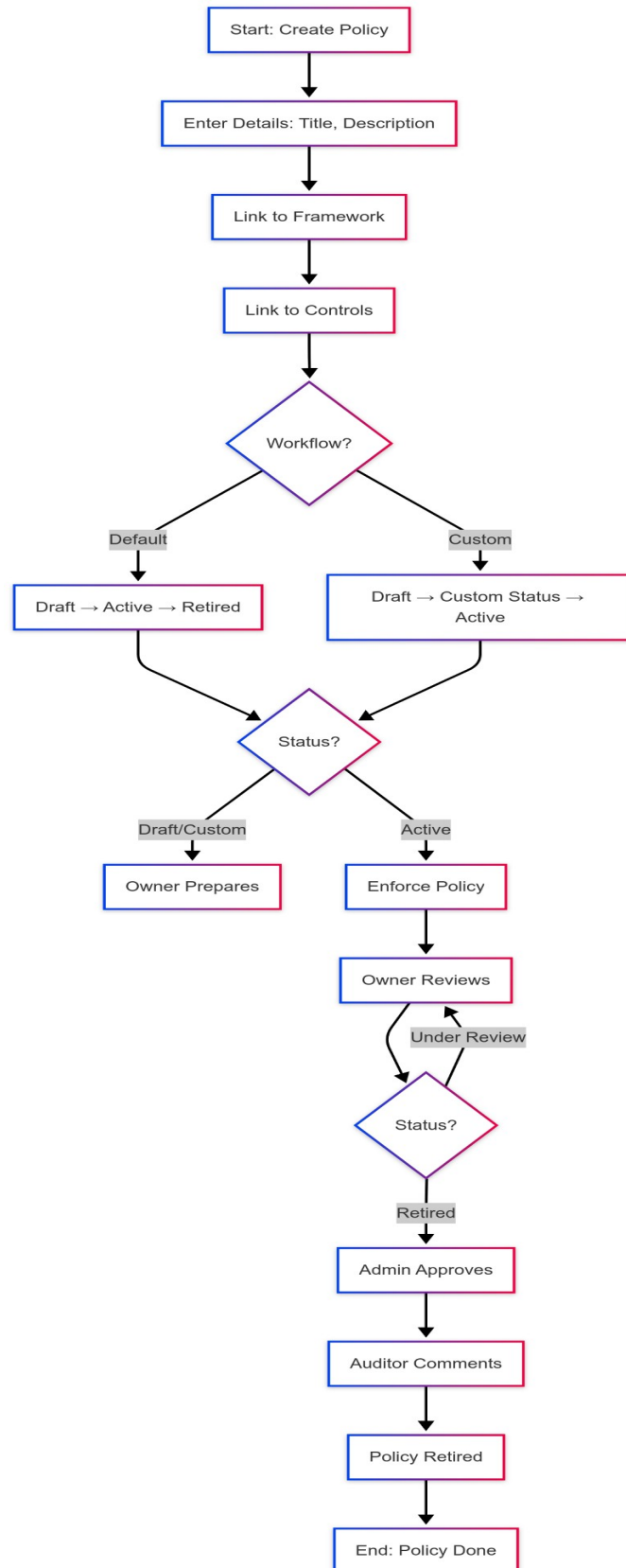
- **Create:** Compliance Officers create policies, link to frameworks/controls.
- **Read:** View policy details and comments.
- **Update:** Update details/status (via workflow).
- **Delete:** Admins/Compliance Officers remove outdated policies..

Status Cycle

- **Draft:** Policy defined, not enforced.
- **Active:** Policy enforced.
- **Under Review:** Being reviewed for updates.
- **Retired:** No longer active, archived(Can't be linked to and new frameworks or controls).

Workflow

- Compliance Officer creates policy (Draft); Admin approves status to Active.
- Owner updates to Under Review.
- Admin update status to Retired
- Auditors add comments during active, review.



7. Workflow Configuration

Purpose

Design automated workflows for status transitions across all modules that has status.

Features

- Create, read, update, and delete workflows.
- Define steps, roles, status changes.
- Enable drag-and-drop configuration.

Create Form Fields

Field	Description	Validation
Workflow ID	Unique ID (like: WF123)	Auto-generated, non-editable
Name	Workflow name	Required, text, min 5, max 100 characters
Steps	Workflow steps (like: draft, Submission, Review)	Required, min 1 step, text/drag-and-drop
Assigned Roles	Roles per step	Required, dropdown/search (Multi select)
Type	Default or Custom (Policy/Control-specific)	Required, dropdown (Default, Policy, Control)
Linked Item	Specific	Optional, dropdown/search

	Policy/Control/Framework/Risk (if Custom)	(Policy name/Control name), required for Custom type
--	--	---

CRUD Operations

- **Create:** Admins create default workflows (module-level) or custom workflows (linked to specific Policy/Control/Framework/Risk); define steps, statuses, roles.
- **Read:** View workflow configurations, including linked policies/controls/Framework/Risk for custom workflows.
- **Update:** Modify steps/statuses/roles/conditions/linked items.
- **Delete:** Admins remove obsolete workflows, linked policies/controls revert to default workflow.

Workflow

- Admin creates workflow, selects Type (Default/Custom).
- For Custom: Links to Policy/Control ID, defines statuses (like: “Awaiting Legal Review”).
- System applies workflow to status changes (like: Policy: Draft → Awaiting Legal Review → Active).
- All actions logged in audit trail.

8. Custom Reports

Purpose

Generate and visualize compliance reports and metrics for frameworks, policies, controls, and audits.

Features

- Create, read, update, and delete reports/dashboards.
- Export reports in PDF/CSV formats.
- Display real-time metrics (like: framework scores, control effectiveness).

Create Form Fields

Field	Description	Validation
Report ID	Unique ID (e.g., RPT123)	Auto-generated, non-editable
Title	Report title	Required, text, min 5, max 100 characters
Type	Report type (like: Risk, Control)	Required, dropdown
Filters	Parameters (like: control statuses, control owners)	Required, dropdown

CRUD Operations

- **Create:** Users generate reports with filters.
- **Read:** View reports with metrics (like: policies in “Awaiting Legal Review”).
- **Update:** Modify report parameters.

-
- **Delete:** Remove outdated reports; creator name retained.

Status Cycle

- None (reports are generated/viewed, no lifecycle).

Workflow

- User selects report type and filters; system generates report.
- Admins export reports.

9. Framework Score Calculation

Purpose

Calculate compliance scores for frameworks based on control effectiveness.

Features

- **Automatic Scoring:** Divides 100 points across controls (like: 4 controls = 25 points each); adjusts based on effectiveness (High: 100%, Medium: 50%, Low: 0).
- **Manual Scoring:** Admins assign custom scores (like: 30, 20, 40, 10), capped at 100.
- **Validation:** Requires at least one control; total score ≤ 100 .

Workflow

- System calculates score on control status update (Effective).
- Compliance Officer reviews score.
- Score displayed on dashboard and included in reports.

10. Auditor Functionalities

Purpose

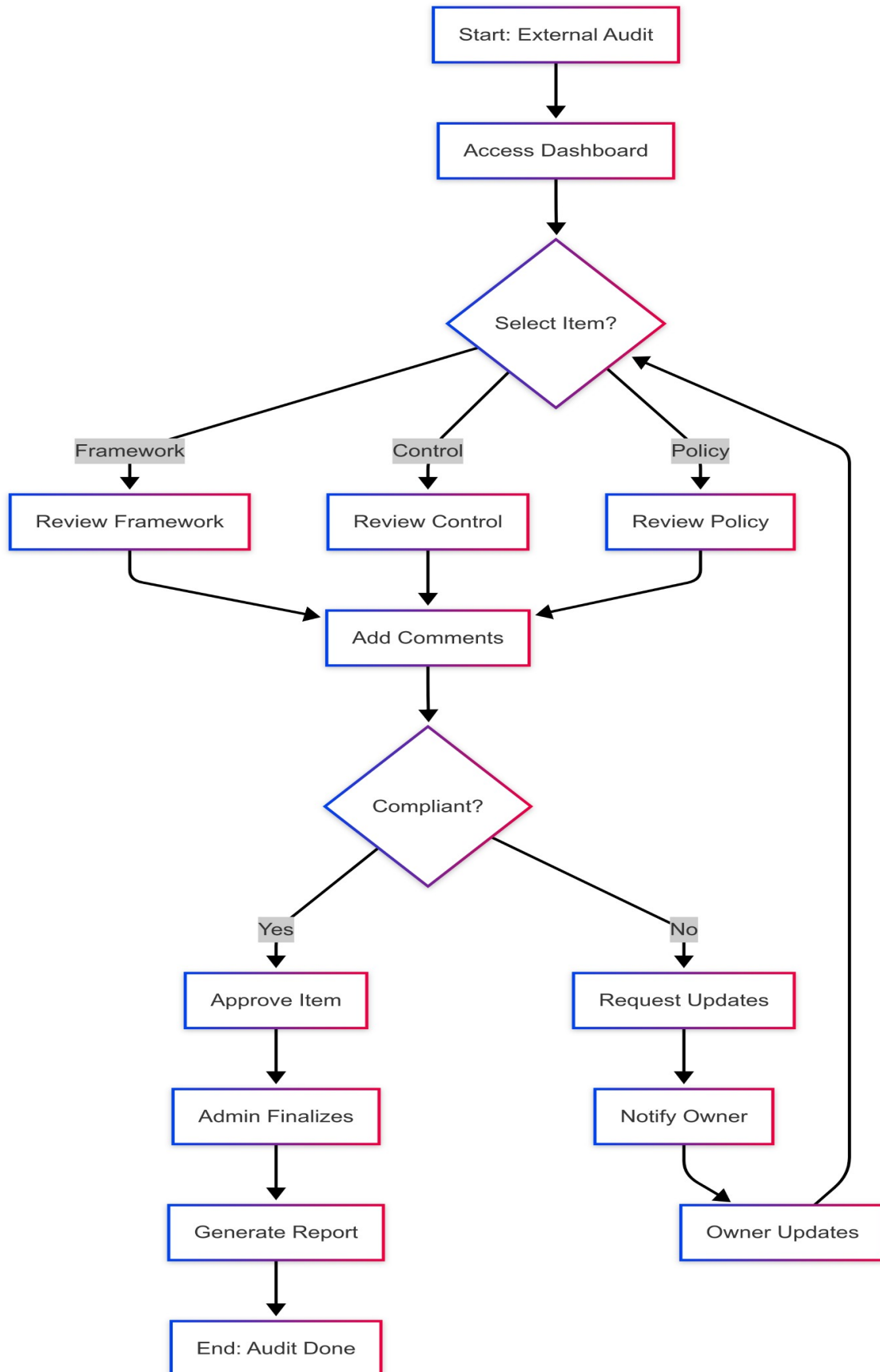
Enable Internal/External Auditors to review and comment on frameworks, controls, and policies.

Features

- Read-only access to frameworks, controls, policies, and custom workflows.
- Add comments (max 1000 characters) on controls/policies.
- View compliance reports and scores.

Workflow

- Auditor accesses Framework/Control/Policy Management Dashboards.
- Reviews details, including custom workflow statuses, adds comments (like: “Control needs testing”).
- Comments saved in records; visible in reports.



11. System Configuration

Purpose

Manage system-wide settings, including categories for risks, compliance, frameworks, controls, policies, incidents, and other modules, enabling Admins to customize the GRC system to organizational needs.

Features

- Create, read, update, and delete categories for all modules (like: Risk: Operational, Cybersecurity; Compliance: Regulatory, Internal).
- Enforce unique category names within each module.
- Audit all configuration changes for traceability.
- Notify Admins of configuration updates via the Notification module.

Create Form Fields

Field	Description	Validation
Category ID	Unique ID (like: CAT123)	Auto-generated, non-editable
Category Name	Category name	Required, text, min 5, max 100 characters, unique per module
Module	Associated module (like: Risk, Framework)	Required, dropdown (Risk, Framework, Control, etc.), Single select
Description	Category details	Optional, text, max 500 characters
Status	Active/Inactive	Required, dropdown, default Active

CRUD Operations

- **Create:** Admins create categories, select module, and set status.
- **Read:** View category details, associated module, and usage (like: risks linked to category).
- **Update:** Modify category name, description, or status; prevent changes if category is in use.
- **Delete:** Deactivate (not delete) categories; prevent deletion if linked to records.

Status Cycle

- **Active:** Category available for use in module forms.
- **Inactive:** Category disabled, not selectable in new records.

Workflow

- Admin creates category (Active); system validates uniqueness per module.
- Category is available in module forms.
- Admin updates/deactivates category; system checks for linked records.
- All actions logged; notifications sent to Admins via Notification module.

12. Roles and Permissions

Purpose

Define and manage roles and granular permissions for all modules, enabling Admins to configure access levels (Create, Read, Update, Delete) for users, ensuring RBAC compliance.

Features

- Create, read, update, and delete roles (like: Admin, Auditor).
- Assign permissions per module (like: Risk: Create, Framework: Read).
- Enforce permission validation (like: Update requires Read).
- Audit role/permission changes.
- Notify Admins of role/permission updates via Notification module.

Create Form Fields

Field	Description	Validation
Role ID	Unique ID (like: ROLE123)	Auto-generated, non-editable
Role Name	Role name (like: Compliance Officer)	Required, text, min 5, max 100 characters, unique
Description	Role details	Optional, text, max 500 characters
Permissions	Module-specific access (like: Risk: CRUD)	Required, checkbox list per module
Notification receive	Notification receive (like: all actions on risk module)	Checkbox for all the modules
Status	Active/Inactive	Required, dropdown, default

		Active
--	--	--------

CRUD Operations

- **Create:** Admins create roles, assign permissions per module.
- **Read:** View role details, permissions, and assigned users.
- **Update:** Modify role name, description, permissions; prevent changes if role is assigned.
- **Delete:** Deactivate roles; prevent deletion if assigned to users.

Status Cycle

- **Active:** Role assignable to users.
- **Inactive:** Role not assignable.

Workflow

- Admin creates role, assigns permissions (Active).
- Role is available in User Management for assignment.
- Admin updates/deactivates role; system checks for assigned users.
- Notifications sent to Admins; actions logged.

12. Notification

Purpose

Manage automated notifications (email or in-website) for system events via two methods: template-based notifications for specific events and general notifications for roles receiving all actions in configured modules, customizable by event type, recipient, and user preferences.

Features

- **Template-Based Notifications:**
 - Create, read, update, and delete notification templates for specific events (like: incident submitted, risk closed).
 - Configure recipients (roles/users), delivery (email/in-website), and message content.
- **General Notifications for Roles:**
 - Enable roles to receive notifications for all actions in modules configured in Roles and Permissions (like: all Control Management actions).
 - Apply to role-assigned users, respecting user preferences.
- Support email and in- website delivery methods.
- Audit notification triggers and deliveries.
- Notify Admins of template or role notification changes.

Create Form Fields (Notification Template)

Field	Description	Validation
Template ID	Unique ID (like: NOTIF123)	Auto-generated, non-editable
Template Name	Name (like: Incident Submitted)	Required, text, min 5, max 100 characters
Event Type	Trigger event (like: Incident Status Change)	Required, dropdown (per module events)

Delivery Method	Email, In-App, or Both	Required, dropdown
Recipients	Roles or specific users	Required, dropdown/search (roles/users)
Message title	Notification title	Required, text, min 5, max 100 characters.
Message Body	Notification content	Required, text, min 5, max 1000 characters.
Status	Active/Inactive	Required, dropdown, default Active

CRUD Operations (Notification Templates)

- **Create:** Admins create templates, define event, recipients, and message.
- **Read:** View template details, event triggers.
- **Update:** Modify template content, recipients, or status.
- **Delete:** Deactivate templates.

Status Cycle (Notification Templates)

- **Active:** Template used for notifications.
- **Inactive:** Template disabled.

Workflow

- **Template-Based:**
 - Admin creates template (Active), links to event.
 - System triggers notification on event, respecting user preferences; delivery logged.
- **General Notifications for Roles:**
 - Admin configures role in Roles and Permissions, selects modules for notifications.

-
- System triggers notifications for all actions in selected modules for role-assigned users, respecting preferences.
 - Example: Compliance Officer role receives notifications for all Control Management actions (create, update, delete).
 - Admin updates templates or role notification settings; notification sent to Admins.

List of Actors

1. End Users

- **Compliance Officer**
 - **Type:** Human (End User)
 - **Description:** A user responsible for creating, updating, and managing policies, controls, and frameworks. Links controls to risks and frameworks, follows custom or default workflows, and reviews framework scores. Receives template-based notifications for specific events (e.g., control effective) and role-based notifications for all actions in configured modules (e.g., Policy Management).
- **Risk Manager**
 - **Type:** Human (End User)
 - **Description:** A user who identifies, assesses, and mitigates risks by creating risk records, calculating scores (Likelihood × Impact), and linking risks to controls. Updates risk statuses (e.g., Open to Mitigated) and receives notifications for risk-related events or all Risk Management actions if configured for the role.
- **Incident Submitter**
 - **Type:** Human (End User)
 - **Description:** A user who submits incident reports (e.g., security breaches) with evidence and selects categories (e.g., Security). Receives template-based notifications for incident status changes (e.g., Rejected, Resolved) and may receive role-based notifications for Incident Reporting actions if assigned a relevant role.
- **Control Owner**
 - **Type:** Human (End User)
 - **Description:** A user assigned to implement and test controls, updating statuses per default or custom workflows (e.g., Draft to Effective). Rates control effectiveness (High/Medium/Low) and receives notifications for control-related events or all Control Management actions if configured.
- **Policy Owner**
 - **Type:** Human (End User)
 - **Description:** A user responsible for preparing, enforcing, and reviewing policies, following custom or default workflows (e.g., Draft to Active). Links policies to frameworks/controls and receives notifications for policy lifecycle events or all Policy Management actions if configured.
- **Framework Owner**
 - **Type:** Human (End User)
 - **Description:** A user who creates and manages compliance frameworks, links controls, and selects scoring methods (automatic/manual). Reviews framework

scores and receives notifications for framework-related events or all Framework Management actions if configured.

2. Back-Office Users

- **Admin**
 - **Type:** Human (Back Office)
 - **Description:** A privileged user with full system access, managing user accounts (invitation-based or direct creation), roles, permissions, and system configurations (e.g., risk categories). Approves status changes, deactivates users, configures workflows, and manages notification templates. Receives notifications for administrative actions (e.g., role created) and all module actions if configured.
- **Incident Manager**
 - **Type:** Human (Back Office)
 - **Description:** A user who reviews submitted incidents, accepts/rejects them with comments, and assigns Owners for resolution. Uses categories from System Configuration and receives template-based notifications for incident events (e.g., submitted) and role-based notifications for all Incident Reporting actions.
- **Internal Auditor**
 - **Type:** Human (Back Office)
 - **Description:** A user with read-only access to frameworks, controls, and policies, responsible for reviewing compliance, adding comments, and approving/rejecting frameworks. Receives template-based notifications for review tasks and role-based notifications for all audit-related module actions (e.g., Framework Management).
- **External Auditor**
 - **Type:** Human (Back Office)
 - **Description:** A third-party user with read-only access to frameworks, controls, and policies, tasked with independent compliance reviews. Adds comments, approves/rejects frameworks, and receives notifications for review tasks or all audit-related actions if configured for the role.
- **System Configurator**
 - **Type:** Human (Back Office)
 - **Description:** A user who manages system-wide settings, including creating and updating categories for risks, frameworks, controls, policies, and incidents (e.g., Operational, Regulatory). Configures default notification preferences and receives notifications for configuration changes or all System Configuration actions.
- **Role Manager**
 - **Type:** Human (Back Office)
 - **Description:** A user who creates and manages roles and permissions, assigning granular access (Create, Read, Update, Delete) per module and configuring general notifications for all actions in selected modules (e.g., Risk Management). Receives notifications for role updates or all Roles and Permissions actions.

- **Notification Manager**

- **Type:** Human (Back Office)
- **Description:** A user who creates and manages notification templates for specific events (e.g., incident rejected) and configures delivery methods (email/in-app). Monitors notification delivery logs and receives notifications for template changes or all Notification module actions.

- **Report Generator**

- **Type:** Human (Back Office)
- **Description:** A user who generates and exports reports/dashboards (PDF/CSV) for compliance metrics (e.g., framework scores, risk statuses). Filters reports by categories and receives template-based notifications for report generation or role-based notifications for all Reporting actions.

3. External Systems

- **Email Service Provider**

- **Type:** System (Third-Party)
- **Description:** Delivers email notifications for template-based events (e.g., incident submitted) and role-based module actions (e.g., all Control Management actions). Integrates with the Notification module to send HTML-formatted emails.

-

Non-Functional Requirements

Non-functional requirements define the system's quality attributes, ensuring it is secure, performant, scalable, usable, and compliant.

1. Performance

- **Response Time:** The system shall respond to user requests (page load) within 4 seconds under normal load (google standards).
- **Throughput:** The system shall handle up to 1,000 concurrent user sessions without degradation.
- **Notification Delivery:** Notifications (email/in-website) shall be delivered within 10 seconds of event triggers.

2. Security

- **Data Encryption:** All data at rest shall use encryption.
- **Authentication:** The system shall enforce strong passwords (8+ characters, uppercase, lowercase, numbers, special characters) .
- **Authorization:** Role-Based Access Control (RBAC) shall restrict access based on roles and permissions defined in the Roles and Permissions module.
- **Audit Logging:** All user actions (like: login, incident submission, role changes) shall be logged with timestamps.

4. Usability

- **User Interface:** The system shall use a responsive, compatible with modern browsers (Chrome, Firefox, Safari, Edge) and devices (desktop, tablet, mobile).
- **Accessibility:** The system shall comply with WCAG 2.1 Level AA standards for accessibility.
- **Localization:** The system shall support English as the primary language.
- **Error Handling:** The system shall display clear, user-friendly error messages for invalid inputs or system issues.

5. Availability

- **Uptime:** The system shall achieve 95% uptime (excluding scheduled maintenance).
- **Maintenance Windows:** Scheduled maintenance shall occur outside peak hours with 24-hour user notifications before maintenance.
- **Disaster Recovery:** The system shall have a Recovery Time Objective (RTO) of 4 hours maximum.

6. Maintainability

- **Code Quality:** The system shall follow clean code principles.
- **Documentation:** The system shall include technical documentation (API specs, architecture diagrams) and user manuals, updated with each release.

Assumptions

Assumptions are expectations about the environment, users, and resources that guide the system's design and implementation.

1. User Environment:

- Users have access to modern browsers (Chrome, Firefox, Safari, Edge, latest versions) and reliable internet connections.
- Users are trained for GRC processes.

2. Organizational Context:

- Stakeholders (like: Compliance Officers, Auditors) are available to perform their roles (like: incident review, framework approval).

3. Infrastructure:

- The system will be hosted on a cloud platform or on-prem.
- The organization provides necessary hardware, network, and database resources.

4. Third-Party Services:

- External systems (Email Service Provider) are available with 99.9% uptime and provide APIs for integration.

5. Development Resources:

- A development team (like: front-end, back-end, DevOps) is available to implement and maintain the system.
- Budget and timeline allow for quarterly updates and security patches.

Constraints

Constraints are limitations that impact the system's design, development, or deployment.

1. **Budget:**

- Development and maintenance costs must align with the organization's allocated budget, potentially limiting features or third-party integrations.

2. **Timeline:**

- The system must be delivered within the agreed project timeline, prioritizing core modules.

3. **Technology Stack:**

- The system must use approved new technologies to align with organizational expertise.
- Legacy systems (if any) may require compatibility, limiting architectural choices.

4. **User Adoption:**

- Users may have varying levels of technical proficiency, requiring a simplified interface and extensive help documentation.
- Resistance to change may necessitate additional training or change management efforts.

Glossary and Acronyms

The glossary and acronyms define key terms and abbreviations used in the GRC system, covering modules (like: Incident Reporting, Risk Management), compliance standards (like: ISO 27001, GDPR), and operational concepts (like: RBAC, workflows). This ensures consistent understanding for stakeholders, including Compliance Officers, Auditors, Administrators, and Developers.

Acronyms

- **BRD:** Business Requirements Document for (this document).
- **CRUD:** Create, Read, Update, Delete (operations for data management).
- **GRC:** Governance, Risk, and Compliance (system focus).
- **ISO 27001:** International Organization for Standardization 27001 (information security standard).
- **ISO 31000:** International Organization for Standardization 31000 (risk management standard).
- **KPI:** Key Performance Indicator (e.g., percentage of incidents closed within 48 hours).
- **MFA:** Multi-Factor Authentication (security requirement for user login).
- **MVP:** Minimum Viable Product (initial system release with core features).
- **RBAC:** Role-Based Access Control (access management based on roles).
- **RTO:** Recovery Time Objective (maximum downtime in disaster recovery, e.g., 4 hours).
- **SSO:** Single Sign-On.
- **UI:** User Interface.
- **WCAG:** Web Content Accessibility Guidelines (like: WCAG 2.1 for accessibility).

Glossary

- **Audit Log:** A record of all system actions.
- **Category:** Configurable classification for modules ,managed via System Configuration module.
- **Compliance Officer:** A user role responsible for creating policies, controls, and frameworks, linking them to risks and standards.

- **Control:** A measure to mitigate risks or ensure compliance, rated as High, Medium, or Low effectiveness.
- **Control Owner:** A user assigned to implement and test a control, updating its status.
- **Custom Workflow:** User-defined status transitions for policies or controls (like: Draft → Under Testing → Effective).
- **Framework:** A compliance structure (like: ISO 27001) linking controls, scored automatically or manually (0–100).
- **Framework Score:** A compliance metric (0–100) calculated as 100 divided by the number of controls, adjusted by effectiveness (High: 100%, Medium: 50%, Low: 0%).
- **Incident:** A reported event with a defined status cycle (Submitted, Rejected, Open, In Progress, Resolved, Closed).
- **Incident Manager:** A user role that reviews and accepts/rejects incidents, assigning Owners for resolution.
- **Notification:** An automated alert (email or in-website) triggered by events, either template-based (specific events) or role-based (all module actions).
- **Policy:** A documented rule (like: data protection policy) linked to frameworks/controls, with a lifecycle (Draft, Active, Retired).
- **Risk:** A potential issue with Likelihood (1–5) and Impact (1–4), scored as $\text{Likelihood} \times \text{Impact}$, linked to controls.
- **Risk Manager:** A user role that identifies, assesses, and mitigates risks, updating their status (like: Open to Mitigated).
- **Role-Based Notification:** Notifications sent to roles configured to receive all actions in a module (like: all Risk Management actions for Risk Manager).
- **Template-Based Notification:** Notifications for specific events (like: incident rejected) with customizable recipients and messages.

Conclusion

This Business Requirements Document (BRD) outlines the requirements for the Governance, Risk, and Compliance (GRC) system, a web-based platform designed to streamline governance, risk management, policy enforcement, and compliance processes. The system supports critical modules, including User Management, Incident Reporting, Risk Management, Control Management, Policy Management, Framework Management, System Configuration, Roles and Permissions, Notification, Workflow Configuration, and Reporting/Dashboards. These modules enable organizations to achieve compliance with global standards such as ISO 27001, ISO 31000, NIST SP 800-53, COSO ERM, and GDPR, while providing a secure, scalable, and user-friendly solution.

MVP Scope

This BRD defines the **Minimum Viable Product (MVP)**, focusing on core functionality to address immediate organizational needs, such as:

- Secure user authentication with RBAC.
- Incident reporting, checks and evidence upload.
- Risk assessment with control linkages and scoring.
- Policy and framework management with custom workflows.
- Automated notifications (template-based and role-based).
- Real-time reporting and audit trails.

The MVP prioritizes essential features to establish a functional GRC platform, validated through stakeholder feedback and initial deployment. However, this is a foundational step, and further enhancements are required to ensure the system remains competitive in the GRC market.

Need for Further Investigation

To evolve the MVP into a fully competitive product, additional investigation is necessary, including:

- **User Feedback:** Conduct user testing with Compliance Officers, Auditors, and Admins to identify usability gaps and feature priorities.
- **Performance Benchmarking:** Validate non-functional requirements, through stress testing.
- **Feature Expansion:** Explore advanced features (like: AI-driven risk prediction, automated compliance gap analysis) based on stakeholder needs.

Competitor Analysis

To position the GRC system as a market leader, a thorough competitor analysis is essential. Key competitors, such as **ServiceNow GRC**, **RSA Archer**, and **MetricStream**, offer robust features like integrated risk management, real-time analytics, and extensive third-party integrations. The analysis should focus on:

- **Feature Comparison:** Evaluate competitors' strengths and gaps.
- **Pricing Models:** Assess subscription-based vs. perpetual licensing to determine competitive pricing.
- **Market analysis:** Identify market&customers needs.

-
- **Customer Feedback:** Analyze user reviews to understand pain points and preferences.

Next Steps

1. **Stakeholder Review:** Distribute the BRD to stakeholders for feedback.
2. **MVP Development:** Initiate development of core modules, targeting initial release.
3. **Competitor Analysis:** Commission a detailed study of ServiceNow, Archer, and MetricStream and other Competitor .